Комплексный аудит BlackHoleMemory по трём техническим заданиям

Дата: 2026-07-31 Task ID: BHM-PDF-AUDIT-2026-07-31 Репозиторий: E:\GitHub\repos\BlackHoleMemory Ветка: main Проверенная ревизия: 379390785054ca71376d8de1a567f533a887b24c Состояние относительно origin/main на старте: совпадает Режим: defensive, read-only для исходного кода Финальный интегратор: Codex /root

1. Операционный вердикт

BlackHoleMemory имеет сильный локальный defensive baseline: SQLite объявлен единственной lifecycle/metadata authority, Qdrant используется как перестраиваемая проекция, caller authentication по умолчанию fail-closed, проектная область проходит через общий middleware, административные REST/MCP-поверхности отделены capability-проверками, локальные валидаторы в основном зелёные, clean-temp full suite завершён 1114/1114.

Но текущий HEAD нельзя считать готовым к новому публичному release и нельзя объявлять полностью закрытым по трём PDF-контрактам.

Главные блокеры:

1. P0 - version-manifest gate красный: static/index.html не содержит требуемый UI marker Runtime v1.8.0-PURE.

2. P0 - доступные v1.8.0 архивы не соответствуют одновременно текущему HEAD, build-contract и trust-contract.

3. P1 - внутренний документационный канон противоречит Git-состоянию и собственному worklist.

4. P1 - SECURITY.md остаётся незаполненным шаблоном с фиктивными версиями.

5. P1 - отсутствуют обязательные CI gates и branch protection для main.

6. P1 - подтверждён project/root authorization bypass в /bhm/code-tools: caller, разрешённый только для project-a, может указать root sibling project-b и получить status/snippet.

7. P1 - подтверждён self-authenticated release signer: verifier принимает произвольный соседний public key без независимого trust anchor.

8. P2 - app.py остаётся монолитом в 16 237 строк и объединяет API, lifecycle, storage, jobs, LLM, MCP, WebSocket, filesystem и process control.

9. P2 - full pytest non-hermetic: ignored .tmp влияет на cleanup-аудит и ломает один тест.

10. P2 - операция поиска, считающаяся read-only на уровне продукта, планирует изменение Qdrant access telemetry.

11. RUNTIME CHECK REQUIRED - BHM runtime после штатного bootstrap отказался стартовать по gate sqlite_authoritative_writer_gate_not_confirmed; Qdrant bootstrap получил Docker Desktop API 500. Полный новый six-worker Deep Scan round не стартовал, но targeted security validation и attack-path analysis для auth/release кандидатов завершены отдельно.

Итоговая оценка:

- Product/local acceptance: проходит существующий P28 validator.

- Release readiness: FAIL.

- Documentation/source-of-truth readiness: FAIL.

- Security design assurance: PARTIALLY VERIFIED.

- Test confidence: высокая для покрытых локальных сценариев, недостаточная для coverage, concurrency, lifecycle и release provenance.

- Рекомендуемая стратегия: не переписывать систему; выполнить 12 последовательных, обратимых work packages с parity gates.

2. Scope, ограничения и доказательная модель

2.1 В scope

- три PDF-ТЗ целиком;

- tracked tree ревизии 379390785054ca71376d8de1a567f533a887b24c;

- src, scripts, config, plugins, infra, tests и публичная документация;

- локальный ignored maintainer-контур .docs как отдельный источник исторического канона;

- REST, MCP, WebSocket, service/lifecycle, storage, filesystem, process, outbound HTTP и LLM-поверхности;

- тесты, линтеры, acceptance validators, release verifiers и benchmark receipts;
- статическая defensive review без эксплуатации.

2.2 Вне scope

- исправление исходного кода;
- публикация, deploy, release, tag move, force-push;
- изменение production или внешних систем;
- эксплуатационные payloads и bypass-инструкции;
- утверждение runtime-инвариантов, которые не удалось воспроизвести;
- завершение 20 000-call local-model replay;
- реанимация retired CAP12-CAP14.

2.3 Классы доказательств

1. VERIFIED STATIC - подтверждено полным кодовым путём, callers/middleware и тестами.
2. VERIFIED EXECUTION - подтверждено командой на текущем checkout.
3. PARTIALLY VERIFIED - есть реализация, но не закрыты все entrypoints или runtime path.
4. PROBABLE DEFECT - конкретный source/control/sink/impact установлен, но validation или deployment precondition не закрыты.
5. ARCHITECTURE RISK - риск сложности, связанности или сопровождаемости без заявления о текущем падении.
6. RUNTIME CHECK REQUIRED - статического анализа недостаточно либо runtime недоступен.
7. UNKNOWN - доказательств не хватает; вывод не подменяется предположением.

3. Источники и артефакты

PDF-контракты:

- BlackHoleMemory Code Review.pdf - correctness, async/concurrency, data consistency, architecture, errors/observability, tests, формат finding и отчёта.

- BlackHoleMemory Defensive Design Review.pdf - 10 defensive invariants, evidence statuses, interface/admin/project/process/filesystem/outbound inventories.

- Техническая карта BlackHoleMemory.pdf - entrypoints, packages, interfaces, stores, jobs, HTTP, LLM, filesystem, process, config, logging, tests, hotspots и data flows.

Созданные аудиторские артефакты:

- docs/audits/bhm-comprehensive-three-pdf-audit-2026-07-31.md - этот отчёт;
- docs/audits/bhm-interface-inventory-2026-07-31.csv - 438 статических interface rows;
- docs/audits/bhm-boundary-inventory-2026-07-31.csv - static candidate inventory границ;
- docs/audits/bhm-comprehensive-three-pdf-audit-2026-07-31.pdf - визуальная версия отчёта.

Инвентаризации CSV являются детерминированными статическими перечнями, а не доказательством безопасности каждой строки.

4. Трассировка требований трёх PDF

4.1 Code Review

Контракт содержит 55 явных check-points и один обязательный meta-check: finding допустим только после чтения полного тела функции, основных callers и tests. Все 56 checks отражены в Appendix A.

Статус по группам:

Группа	Checks	Статус	Основной результат
Correctness	10	PARTIALLY VERIFIED	version gate, non-hermetic cleanup, stale docs/release identity
Async/concurrency	10	PARTIALLY VERIFIED	lifecycle тесты есть, но full concurrency map не закрыт
Data	9	PARTIALLY VERIFIED	SQLite authority подтверждена; projection side effect и runtime drift требуют контракта

Группа	Checks	Статус	Основной результат
Architecture	10	VERIFIED RISK	app.py, code_graph.py и developer_agent.py требуют staged decomposition
Errors/observability	9	PARTIALLY VERIFIED	correlation/telemetry присутствуют фрагментарно; единый error taxonomy не доказан
Tests	7	PARTIALLY VERIFIED	1114 collected; coverage threshold и hermetic isolation отсутствуют
Caller/test meta-check	1	APPLIED TO PROMOTED FINDINGS	security candidates без полной tail-validation оставлены probable

4.2 Defensive Design Review

Все 10 инвариантов классифицированы в разделе 9. Обязательные inventories:

- Interface inventory: COMPLETE STATIC INVENTORY, 252 REST/WS decorators и 186 static MCP tool decorators.

- Authentication matrix: общий middleware и policy mapping изучены; runtime caller configuration не перепроверена после bootstrap failure.

- Administrative matrix: capability prefixes и MCP classification изучены; exhaustive per-operation semantic review остаётся work package.

- Project trace: middleware, service/store authority и основные stores изучены; global object-id siblings требуют отдельного closure.

- Process/filesystem/outbound inventories: детерминированные candidate rows созданы; high-impact rows требуют пофайловой validation.

4.3 Technical Map

Все 19 категорий карты и пять data-flow схем отражены в разделах 5-8 и Appendix B. Для ключевых компонентов указаны path, responsibility, input/output, dependencies, callers и callees.

5. Техническая карта

5.1 Исполняемые компоненты и entrypoints

Компонент	Path	Ответственность	Вход	Выход	Основные зависимости
FastAPI runtime	src/blackholememory/app.py	composition, lifespan, REST, WS, UI, services	HTTP/WS, env, runtime state	JSON, files, WS events	FastAPI, SQLite, Qdrant, LLM services
MCP runtime	src/blackholememory/bhm_mcp.py	MCP tool registration and wrappers	JSON-RPC/MCP calls	bounded tool results	app services, auth/capability
SQLite repository	src/blackholememory/memory_repository.py и store modules	authoritative lifecycle/metadata	typed service commands	rows/artifacts/transactions	sqlite3
Qdrant projection	app/search/index services	rebuildable vector/search projection	embeddings, metadata payload	ranked ids/metadata	Qdrant
Mem0 integration	app/config services	semantic/logical layer	memory content/query	semantic candidates	local HTTP client/config
LangGraph/agents	agents/developer_agent.py и graph modules	orchestration/stateful flows	task/state/context	plans, proposal state	LangGraph, local LLM
Code graph	code_graph.py, repository_index.py	repository metadata graph/index	allowlisted repo	SQLite graph/projection	parsers, git, filesystem
Launcher/runtime scripts	scripts/*.ps1, scripts/*.py	startup, health, build, release	operator arguments/env	processes, logs, artifacts	PowerShell, uv, Docker, PyInstaller
Browser UI	src/blackholememory/static	dashboard and galaxy	REST/WS responses	rendered UI/session flow	browser JS

5.2 Package structure

Ключевые зоны:

- app/composition: app.py, config.py, runtime endpoint helpers;

- auth/boundaries: caller_auth.py, capability.py, mcp_surfaces.py;

- memory domain: repository/store/artifact/link/task/session modules;

- retrieval: search, ranking, Qdrant projection, context compilation;

- graph/index: code_graph.py, repository_index.py, change_impact.py;
- agents/LLM: agents/, llm_long_tasks.py, model routing/cache/policy;
- operations: scripts, control, infra, plugins;
- UI: static assets and session endpoints;
- tests: 223 test files, 1114 collected tests.

5.3 Storage authority

- SQLite WAL: единственная authoritative lifecycle/metadata база.
- Qdrant: rebuildable projection/search; не должен быть authority.
- Mem0: semantic/logical abstraction; direct vector authority запрещена.
- LangGraph: orchestration/state, а не постоянная data authority.
- Local files: config, runtime logs, release artifacts, indexes and receipts.

Критическое правило для дальнейшей реализации: любое изменение Qdrant/Mem0 должно быть воспроизводимо из SQLite или сопровождаться явным non-authoritative contract.

5.4 Background jobs

Статическая boundary inventory содержит 41 candidate line для asyncio task/background queue/executor patterns. Крупные семейства:

- LLM jobs: create/status/result/cancel;
- hooks: compact/idle queue;
- repository indexing/watch cycles;
- projection/access telemetry updates;
- lifecycle startup/shutdown tasks.

Полный lifecycle closure не доказан из-за runtime bootstrap failure; нужен отдельный cancellation/partial-start work package.

5.5 Outbound HTTP

Статическая inventory содержит 200 candidate lines для httpx/requests/aiohttp/urllib/PowerShell web calls. Это включает:

- local BHM/Mem0/LLM calls;
- Qdrant and health calls;
- release/ops diagnostics;
- scripts that contact local or operator-configured endpoints.

Наличие match не означает network egress. Для local-only guarantee требуется endpoint canonicalization matrix: scheme, hostname/IP, IPv4/IPv6, redirects, proxy env, response limit и cloud fallback.

5.6 Filesystem

Static candidate inventory: 1270 filesystem-related lines. Высокорисковые семейства:

- repository root allowlisting and resolve;
- code indexing/snippet access;
- admin export/import;
- release staging/signing;
- artifact export/restore;
- temp files and runtime logs;
- PowerShell copy/move/remove/archive operations.

5.7 External process execution

Static candidate inventory: 268 process-related lines. Подтверждённый safe pattern в release verifiers: argv-list без shell. Полный audit всех process locations не закрыт и должен проверять executable, structured args, cwd, timeout, output bound, child cleanup, PATH dependence и argument provenance.

5.8 Config, logging and observability

Конфигурация распределена между pyproject, config/version-manifest.json, environment, runtime endpoint files, MCP registration, PowerShell scripts и ignored local .docs.

Проблемы:

- один канонический version marker не согласован с UI implementation;

- security/auth setup не документирует caller token lifecycle;

- локальный .docs canon не маршрутизируется публичным AGENTS.md;

- нет executable docs/link integrity gate;

- runtime logs показали точную fail-closed причину, что является положительным control.

6. Интерфейсная карта

Статический inventory:

Surface	Количество	Примечание
REST GET	75	public, auth-only, project-scoped и admin families
REST POST	172	большинство mutating/preview/job/LLM operations
REST DELETE	4	delete/hard-delete paths
WebSocket	1	/bhm/ws
Static MCP decorators	186	code-defined tools
Live MCP tools до runtime failure	35	attached current-session contract; не равно static surface

Полная таблица path/name, handler, file и line находится в bhm-interface-inventory-2026-07-31.csv.

6.1 Authentication design

Evidence:

- caller_auth.py:22-39 - explicit anonymous paths/prefixes;

- caller_auth.py:157-177 - explicit route policy with fail-closed AUTH_ONLY default;

- app.py:2014-2140 - global caller/project/admin middleware;

- app.py:14323-14335 - WebSocket bearer/origin checks;

- config/mcp-registration.json - bearer token via BHM_CALLER_TOKEN.

Статический вывод: default route policy fail-closed; /bhm subtree project-scoped, специальные health/MCP/telemetry paths auth-only, ограниченный anonymous allowlist.

Ограничение: live runtime configuration после bootstrap failure не подтверждена, а public docs не дают воспроизводимый token provisioning/rotation runbook.

6.2 Administrative operations

Evidence:

- capability.py:14-63 - explicit admin/destructive prefix set;

- capability.py:66-82 - secret retrieval and constant-time validation;

- app.py:2132-2138 - REST capability guard;

- app.py:1727-1767 - MCP surface/capability enforcement;

- app.py:9413-9462 - admin snapshot path and import/export operations.

Административные семейства:

- import/export and policy;

- hard delete, batch delete, archive/restore;

- repair, schema upgrade and reindex;

- link/relation apply/prune;

- project retirement;

- service restart and MCP repair;

- artifact mutation.

Риск: prefix-based classification должна иметь executable parity test против всех 252 routes и 186 tool definitions, иначе новая mutating operation может остаться в default project-auth tier.

6.3 Project scope

Evidence:

- caller_auth.py:41-78 - auth-only/project path families and project keys;
- caller_auth.py:194-238 - recursive project extraction and authorization;
- middleware reads path/query/body within MAX_PROJECT_INSPECTION_BYTES;
- SQLite is authoritative; Qdrant/Mem0 are downstream projections/layers.

Открытые проверки:

- все global object-id operations должны доказать project ownership at read/update/delete time;
- batch/import/restore paths должны проверять каждый item;
- jobs/cache/export/diagnostics должны сохранять и перепроверять project scope;
- Qdrant filters должны быть sibling-tested для каждого search mode.

7. Пять data-flow схем

7.1 HTTP request

Client -> FastAPI middleware -> anonymous/auth-only/project policy -> bearer principal -> project authorization -> admin capability if required -> handler -> service/repository -> SQLite authority -> optional Qdrant/Mem0 projection -> response/error telemetry.

7.2 MCP request

MCP client -> streamable HTTP /mcp -> bearer authentication -> MCP tool registry -> surface classification -> optional admin capability from metadata -> typed wrapper -> shared service/repository -> bounded result.

7.3 Memory save and search

Save: caller/project validation -> policy/redaction/schema -> SQLite transaction -> artifact/link updates -> rebuildable Qdrant projection -> receipt.

Search: caller/project validation -> SQLite/Qdrant retrieval -> filters/ranking -> response -> scheduled Qdrant access telemetry update.

Последняя стрелка является скрытым side effect для операции, воспринимаемой как read-only.

7.4 LLM request

REST/MCP/agent input -> model policy/router -> local endpoint validation -> bounded prompt/context -> local LLM HTTP -> response parsing/limits -> cache/telemetry -> proposal or semantic result.

Runtime proof local-only endpoint policy не завершён.

7.5 Patch proposal

Task/context -> LangGraph/developer agent -> repository metadata/snippet access -> change-impact/convention analysis -> patch proposal -> explicit operator/admin apply step.

Требование: proposal generation не должна вызывать write/apply implicitly; этот invariant частично подтверждён именованием preview/plan and apply separation, но требует exhaustive call-graph test.

8. Findings summary

ID	Класс	Priority	Confidence	Область	Краткий вывод
BHM-REL-001	confirmed defect	P0	High	release/version	version-manifest validator FAIL
BHM-REL-002	confirmed defect	P0	High	release artifact	root v1.8.0 ZIP fails build/trust
BHM-REL-003	confirmed defect	P0	High	release identity	HEAD remains 1.8.0 after 24 commits past tag

ID	Класс	Priority	Confidence	Область	Краткий вывод
BHM-DOC-001	confirmed defect	P1	High	canon	.docs PROJECT/NEXT/ WORKLIST stale and contradictory
BHM-DOC-002	confirmed defect	P1	High	receipts	three canonical receipt references missing
BHM-SEC-001	confirmed defect	P1	High	policy	SECURITY.md is unfilled template
BHM-CI-001	architecture/process risk	P1	High	CI	no pytest/lint/release/acceptance CI and no branch protection
BHM-AUTH-001	documentation defect	P1	High	MCP auth	caller token lifecycle/runbook absent
BHM-AUTHZ-001	confirmed security defect	P1	High	project/root isolation	/bhm/code-tools accepts authorized project plus sibling root
BHM-UI-AUTH-002	confirmed conditional defect	P2	High behavior	local UI auth	anonymous loopback process can mint configured principal session
BHM-TEST-001	confirmed defect	P2	High	hermeticity	ignored .tmp breaks cleanup test
BHM-TEST-002	architecture risk	P1	High	assurance	no coverage threshold/gate
BHM-TEST-003	confirmed defect	P2	High	acceptance	WI17 trusts supplied pytest count
BHM-ARCH-001	architecture risk	P2	High	app.py	16 237-line multi-responsibility monolith
BHM-ARCH-002	architecture risk	P2	High	hotspots	code_graph and developer_agent oversized
BHM-DATA-001	design inconsistency	P2	High	Qdrant	read/search schedules projection mutation
BHM-RUNTIME-001	runtime check required	P1	High	startup	writer gate not confirmed; app fails closed
BHM-RUNTIME-002	runtime check required	P2	Medium	Qdrant	Docker Desktop API 500 during bootstrap
BHM-PATH-001	probable defect	P2	Medium	runtime path	mcp_readiness fallback uses runtime instead of .runtime
BHM-REL-TRUST-001	confirmed security defect	P1	High	signing	arbitrary adjacent public key accepted as external verified
BHM-REL-TRUST-002	confirmed security defect	P2	High	signing receipt	signer/source metadata tampering still verifies
BHM-REL-KEY-003	hardening-only	P1 hardening	High primitive	signing key	operator-only precondition; catastrophic key disclosure risk
BHM-REL-SOURCE-004	confirmed security defect	P2	High	release provenance	mutable/untracked source and stale clean-state claim
BHM-REL-PROV-005	confirmed security defect	P2	High	provenance	arbitrary revision plus source_dirty=false verifies
BHM-REL-TOCTOU-006	hardening-only	P3	Medium	verifier race	consumer reopen race not proven
BHM-REL-WRITE-007	confirmed conditional defect	P2	High primitive	artifact writer	precreated hardlink target is overwritten
BHM-MCP-ERR-003	confirmed security defect	P2	High behavior	MCP errors	raw exception text can echo bearer/API-key-like secret
BHM-FMT-001	hygiene debt	P3	High	formatting	536 files would be reformatted
BHM-BENCH-001	evidence gap	P2	High	benchmark	20 000-call local-model replay has no receipt
BHM-OBS-001	architecture risk	P2	Medium	errors	unified error/correlation taxonomy not proven

ID	Класс	Priority	Confidence	Область	Краткий вывод
BHM-PROJ-001	evidence gap	P1	Medium	isolation	global ID siblings not exhaustively closed
BHM-RES-001	evidence gap	P1	Medium	resource limits	complete limit matrix not proven
BHM-LLM-001	evidence gap	P1	Medium	local-only	redirect/proxy/IPv6/fallback matrix not closed

9. Defensive invariant verification

Invariant	Status	Подтверждённые controls	Недостающие доказательства
1. Authentication	PARTIALLY VERIFIED	fail-closed route policy, bearer compare, WS auth/origin, MCP bearer config	anonymous local UI bootstrap mints principal-derived token; host-user boundary not enforced
2. Admin operations	PARTIALLY VERIFIED	explicit capability prefixes, constant-time check, REST/MCP guards	generated route/tool parity and internal-call equivalents
3. Project isolation	NOT VERIFIED ON CODE-TOOLS ROOT PATH	principal allowed projects, request project extraction, project-default logic	confirmed project/root mismatch reaches sibling repository status/snippet
4. Filesystem confinement	PARTIALLY VERIFIED	repo allowlisting, resolve checks, admin-export root	symlink/junction/reparse, TOCTOU, all 1270 candidate lines
5. Process execution	PARTIALLY VERIFIED	safe argv in reviewed release validators	exhaustive 268-line closure, timeouts/output/child cleanup
6. Local-only LLM	RUNTIME CHECK REQUIRED	local endpoint architecture and no claimed cloud authority	IPv4/IPv6, redirects, proxy env, response limit, fallback
7. Proposal-only	PARTIALLY VERIFIED	preview/plan/apply naming separation, graph operations read-only/proposal-only	complete call graph from generation to every write/apply
8. Secret redaction	PARTIALLY VERIFIED	token compare, fingerprint-only log example, redaction/policy tools	nested structured values across logs/errors/LLM/export/browser
9. Resource limits	PARTIALLY VERIFIED	MAX_PROJECT_INSPECTION_BYTES, bounded graph/snippet descriptions	one authoritative limit matrix for every surface
10. Lifecycle	PARTIALLY VERIFIED	fail-closed startup, lifespan, explicit jobs/cancel routes	successful startup/shutdown, partial-start cleanup, connection/task closure

Ни один PARTIALLY VERIFIED статус не трактуется как подтверждённое нарушение. Это backlog доказательств и consistency work.

10. Детальные подтверждённые дефекты

BHM-REL-001 - version-manifest gate

- Категория: correctness/release.

- Priority: P0.

- Evidence: scripts/validate-bhm-version-manifest.ps1 требует literal UI identity; config/version-manifest.json объявляет 1.8.0; static/index.html получает data.version динамически, но marker отсутствует.

- Наблюдаемое поведение: PASS=12, FAIL=1.

- Риск: release identity gate не может доказать согласованность UI/runtime.

- Минимальный fix: выбрать один канонический контракт - безопасно сгенерированный marker или validator, проверяющий binding вместо literal.

- Regression test: test_version_manifest должен запускать тот же UI source check.

BHM-REL-002/003 - stale release identity

- Current code: version 1.8.0.

- Historical v1.8.0 tag: 24 commits behind HEAD; tag не двигать.

- Root ZIP: checksum и Ed25519 math PASS, build verifier FAIL на LICENSE, trust verifier FAIL на build-inputs.json.

- .artifacts ZIP: build/trust PASS, но source revision 13 commits behind HEAD.

- Требование: новый SemVer, exact tracked-tree build, provenance and rollback receipts.

BHM-DOC-001/002 - canonical drift

- .docs/PROJECT.md и NEXT-SESSION.md указывают 2b5a611 вместо 3793907.
- Они заявляют WL-001..WL-021; фактически WL-001..WL-023 done.
- NEXT-SESSION предлагает создать уже существующий WL-022.
- WORKLIST summary считает 20/21 items, фактически 23.
- Canonical plan одновременно говорит P0-P25 closed и active/unclosed P25.
- Три referenced receipts отсутствуют.
- Нельзя фабриковать receipts: только восстановление из доказуемого источника либо explicit unavailable.

BHM-TEST-001 - non-hermetic cleanup audit

- Первый full suite: 1113 passed, 1 failed, 1 warning.
- Failure: test_cleanup_audit_is_read_only_and_utf8_clean.
- Причина: scripts/audit-bhm-cleanup.py сканирует ignored .tmp; UTF-16 local audit file попал в scope.
- Риск: локальный мусор меняет результат canonical validation.
- Fix: run against git-tracked snapshot or explicit local/runtime exclusions.
- Test: fixture with ignored binary/UTF-16 files must not affect result.
- Clean-temp rerun после удаления только audit intermediate: 1114 passed, 1 warning in 212.71s.
- Вывод: product tests зелёные, но gate non-hermetic, потому что результат зависел от ignored локального файла.

BHM-DATA-001 - hidden Qdrant side effect

- app.py:9630-9665 builds access updates and calls Qdrant set_payload.
- search path schedules _schedule_vector_access_updates.
- tests monkeypatch scheduler to no-op in read-only scenarios.
- Риск: read-only audit/search may mutate projection and invalidate before/after receipts.
- Fix options:

1. classify operation as projection-mutating and emit receipt; 2. make telemetry opt-in/async with explicit flag; 3. separate query from access accounting.

- SQLite remains authority; этот finding не доказывает SQLite data loss.

BHM-RUNTIME-001/002 - fail-closed bootstrap

Штатный bootstrap создал process, но app lifespan завершился:

sqlite-authoritative memory mode is not ready: sqlite_authoritative_writer_gate_not_confirmed

Qdrant bootstrap log:

Docker Desktop Linux engine API returned 500 while resolving pinned image.

Положительный control: runtime не продолжил работу в неоднозначном authoritative mode. Открытый вопрос: какой операторский receipt/flag должен подтвердить writer gate и как startup должен сообщать recovery path без ручного log mining.

11. Security validation and attack-path results

Новый six-worker repository-wide Deep Scan round не стартовал: BHM MCP/runtime был недоступен. Однако targeted security validation и attack-path analysis по наиболее критичным auth/release surfaces завершены отдельным defensive lane: 40 targeted tests passed, source boundary verifier PASS, dynamic receipts сохранены в Codex Security temp artifacts. Эти findings можно считать подтверждёнными в заявленных preconditions; deployment-dependent claims остаются conditional.

BHM-AUTHZ-001 - project/root binding bypass

- Severity: P1 / High, confidence High.
- Entrypoint: src/blackholememory/app.py:12003-12049, POST /bhm/code-tools.
- Caller auth: app.py:2047-2128 validates caller/project scope.
- Root contract: app.py:2772-2849 accepts project and root; resolver app.py:11891-11924 allows any path inside shared repos_root.
- Missing binding: app.py:11971-11976 does not prove requested root is the canonical root registered for authorized project.

- Sinks: app.py:12295-12418 (write/index/watch), app.py:12566-12864 (code search/snippet); source read/redaction in src/blackholememory/code_search.py:350-400.

- Dynamic evidence: caller scoped to project-a, request project=project-a and root=project-b; status and redacted snippet from project-b/private.py returned HTTP 200.

- Impact: cross-project repository metadata/source exposure and possible cross-project indexing/watch side effects.

- Minimal fix: canonical project registry owns exact realpath/root-id; authenticate -> canonicalize project -> resolve registered root -> reject mismatch with 403 before filesystem touch.

- Regression: sibling temporary repos; status/index(plan/apply)/watch/code_search/code_snippet/package/dependency/graph across REST, MCP and UI proxy; absolute/relative/case/symlink/reparse aliases.

BHM-UI-AUTH-002 - configured-principal loopback bootstrap

- Severity: P2 / Medium, confidence High; impact becomes higher on a shared multi-user Windows host.

- Exempt routes: caller_auth.py:14-31.

- Loopback/header checks: app.py:1867-1911.

- Bootstrap: anonymous GET /bhm/ui/session/bootstrap at app.py:14178-14221 calls configured_caller_principal() and returns bootstrap token; exchange/cookie at app.py:14224-14294.

- Dynamic evidence: canonical loopback TestClient without Authorization received HTTP 200 and bootstrap_token.

- Countercontrols: loopback-only listener, exact host/port/scheme, origin/fetch metadata, one-time token, HttpOnly/SameSite=Strict.

- Missing boundary: loopback process is not the same as OS user; configured principal is global.

- Fix: default bearer-minted bootstrap; direct mode only via explicit single-user flag, or bind mint to same-user named pipe/launcher nonce with ACL.

- Regression: anonymous loopback default denied; opt-in contract explicit; another local process/user cannot mint; remote/cross-origin/rebinding denied.

BHM-MCP-ERR-003 - raw exception secret echo

- Severity: P2, confidence High.

- Location: app.py:1772-1777 raw JSON-RPC error construction.

- Dynamic evidence: monkeypatched bhm_health raised an exception containing Authorization: Bearer sk-test-secret; JSON-RPC -32603 response echoed the full token.

- Impact: provider/API credentials can cross the MCP error boundary.

- Fix: central redact_secret_text before JSON-RPC serialization; stable public error code; internal logs retain only redacted fingerprint.

- Regression: bearer, API key, DSN, cookie and path secrets in nested exception messages.

BHM-REL-TRUST-001 - self-authenticated signer identity

BHM-REL-TRUST-001 - self-authenticated signer identity

- Source/control/sink: verify-release-signature.py и verify-release-trust.py принимают public key рядом с artifact и проверяют математику подписи.

- Missing control: pinned fingerprint/trusted-key registry/signer allowlist не найден в прочитанных файлах.

- Impact: ложное утверждение доверенного signer при скомпрометированной distribution directory.

- Dynamic evidence: generated fresh Ed25519 key plus adjacent .pub/.sig accepted as authority=external, status=verified, independent_external=true.

- Fix: pinned fingerprint/trusted-key registry, signer allowlist, rotation/revocation; arbitrary generated key must fail.

BHM-REL-TRUST-002 - unsigned receipt metadata

- Подписывается raw archive digest.

- Authority, independent_external, source_revision, created_at и status живут отдельно.

- Impact: post-signing metadata confusion без подделки archive signature.

- Fix: domain-separated signed envelope с canonical serialization.

- Dynamic evidence: after valid signing, signer.id and source_revision were tampered; verifier still exited 0 and returned forged signer.

BHM-REL-KEY-003 - signing key containment

- SigningKeyPath проверяется на существование, но containment вне repo/staging не доказан.
- Release copy recursively включает shipped directories.
- Fix: require key outside repo/staging/output and reject reparse/hardlink aliases.

BHM-REL-SOURCE-004/PROV-005 - exact-tree provenance

- Early git status excludes untracked files and can become stale.
- Build uses live working tree.
- Provenance consumes env/source metadata without byte-for-byte tree binding.
- Fix: build only from git archive/clean detached worktree; compute tree digest and reverify before signing/promotion.
- Dynamic evidence: untracked payload invisible to --untracked-files=no; arbitrary 40-hex source_revision with source_dirty=false passed trust verification.

BHM-REL-TOCTOU-006/WRITE-007

- Archive may change after initial hash in a shared writable directory.
- Artifact writers need no-follow/create-new semantics and reparse-point policy.
- Severity depends on build directory ACL and attacker concurrency; keep as P2/Low until deployment preconditions are proven.
- REL-WRITE-007 dynamic primitive: precreated hardlink <archive>.sig -> victim.txt was overwritten by signer. Keep P2 conditional on output ACLs; enforce exclusive no-follow create.

12. Architecture and data-consistency findings

BHM-ARCH-01 - LangGraph contract drift

- P2 / High confidence.
- Canon says LangGraph is the main orchestration/stateful-flow controller.
- graph.py:6-22 contains only action/status, one bootstrap node and compile without persisted checkpointer.
- API uses it at app.py:1993 and /graph/status app.py:14123-14126.
- Real multi-node graph lives in agents/developer_agent.py:4514-4560 and is not imported by app.py.
- Fix: do not graphify simple CRUD; move only multi-step lifecycle/repair/task/checkpoint/LLM flows into versioned persisted graphs with idempotency/resume/retry/rollback.

BHM-ARCH-02 - monolith and change blast radius

- P2 / High confidence.
- app.py:16 237 LOC, 723 functions, 168 classes, 252 FastAPI decorators.
- Runtime globals/lifespan/MCP/locks: app.py:1931-2003.
- Request/domain models: app.py:2340-3868.
- Storage/services/workflows: app.py:3891-11138.
- Route surface: app.py:11141-16236.
- Other hotspots: code_graph.py 5759 LOC, developer_agent.py 4757, repository_index.py 2560, bhm_mcp.py 2153.
- Fix: compatibility-preserving router/service/composition slices; keep app:app facade and monkeypatch names until migration closes.

BHM-ARCH-03 - MCP -> REST self-loopback

- P2 / High confidence architectural coupling, not standalone runtime exploit.
- Dispatcher: app.py:1743-1775.
- Streamable gateway thread handoff: mcp_streamable_http.py:663-673.
- MCP tools create httpx client to DEFAULT_BASE_URL and use BHM_CALLER_TOKEN: bhm_mcp.py:189-209; _get/_post/_delete at :288-306.
- Risk: duplicated auth/serialization/error handling, self-network dependency and failure-mode divergence.
- Fix: shared application/use-case services; REST/MCP thin adapters; preserve standalone client only for external compatibility.

BHM-ARCH-04 - REST/MCP schema drift

- P2 / High confidence.

- REST MemoryMetadata includes importance_score at app.py:2457.

- MCP model ends at version at bhm_mcp.py:152; taxonomy hint bhm_mcp.py:19-26 omits importance_score.

- extra=allow can hide the drift while schemas disagree.

- Fix: shared contract package or generated schema parity gate.

BHM-DATA-01 - JSON sidecars split declared SQLite authority

- P1 / High confidence architecture/data risk.

- Canon requires SQLite-only lifecycle/metadata.

- app.py:3910-3978 defines JSON sidecars for slots, lessons, links, checkpoints, maps, ADRs, handoffs, sessions, tasks, contexts, risks, validation, entities and policy.

- Runtime load/save: app.py:4751-4937 and :5219-5224.

- SQLite already has memory_artifacts/memory_links schema and repository APIs in memory_repository.py:306-341 and :831-976.

- Fix: transactional SQLite migration with backup/reconciliation; keep sidecars only as export/read model after cutover.

BHM-CODE-ARCH-01 - parser capability overclaim

- P2 / High confidence truthfulness risk.

- code_graph.py:48-140 registers python-ast but most other languages as regex.

- code_graph.py:185-240 labels all registered parsers parsed/structural_edges=true.

- JS/TS extraction is regex at :4942-5027.

- Fix: capability tiers ast/compiler/regex-heuristic/metadata-only, confidence and golden corpus.

BHM-FS-ARCH-01 - resolved symlink provenance loss

- P2 / High confidence defensive inconsistency.

- repository_index.py:621-625 resolves candidate first.

- probe_repository_state at :751-755 checks is_symlink() after resolve.

- Escape may be blocked, but original symlink/junction provenance can be lost.

- Fix: lstat/reparse inspection before resolve plus containment after resolve; Windows junction/symlink/hardlink matrix.

13. Verified defensive controls

1. Caller auth configuration fails closed if token missing/short or project scopes absent.
2. Bearer and admin capability comparisons use hmac.compare_digest.
3. Route policy defaults to AUTH_ONLY outside explicit anonymous/project mappings.
4. /bhm paths default to project-scoped policy.
5. WebSocket checks bearer and origin and closes with explicit codes.
6. Admin route list is explicit and reviewable.
7. Admin snapshot path is constrained under runtime/admin-exports.
8. SQLite authority/Qdrant projection separation is documented and executable acceptance-aware.
9. Release trust verifier rejects unsafe archive paths and does not extract.
10. Release verifier subprocess calls use structured argv, not shell.
11. Runtime startup fails closed when writer authority is not confirmed.
12. Public-tree validator passes over 1615 public files.
13. Dependency lock validator passes.
14. Static encoding validator passes for its configured scope.
15. Ruff lint passes across src, tests and scripts.
16. Deterministic 1000 x 10 benchmark is reproducible with identical fixture/report digest.

14. Tests and coverage map

13.1 Current results

Check	Result
pytest collect-only	1114 tests
full pytest clean-temp rerun	PASS, 1114/1114, 1 warning, 212.71s
full pytest contaminated audit-temp	1113 pass, 1 fail; proves non-hermetic gate
Ruff lint	PASS
Ruff format check	FAIL baseline: 536 would reformat, 49 formatted
public tree	PASS, 1615 checked
P28 acceptance	PASS, local_product_ready=true
dependency lock	PASS
static encoding configured scope	PASS
version manifest	FAIL 1 of 13
deterministic benchmark	PASS, 1000 cases x 10
local-model replay	INCOMPLETE, no receipt
targeted auth/release validation	PASS, 40 tests + dynamic receipts
source-boundary verifier	PASS, ok=true

13.2 Assurance gaps

- no pytest coverage measurement or fail-under threshold;
- no branch coverage target for auth/admin/project/lifecycle;
- no CI that binds receipts to commit SHA;
- WI17 accepts operator-supplied pytest count;
- no hermetic temp/runtime isolation;
- no complete startup/shutdown partial-failure matrix;
- no concurrency stress for duplicate jobs, locks and cancellation;
- no generated parity test: every mutating route/tool must be admin-classified;
- no generated parity test: every project-scoped operation filters storage/projection;
- no release build-from-exact-tree regression;
- no docs/link integrity executable gate;
- no test proving search read-only vs projection-mutating contract.

15. P0-P3 master backlog

P0 - release blockers

ID	Работа	Owner	Depends	Acceptance
P0-01	Reconcile version-manifest and UI marker contract	Runtime/UI	none	validator 13/13 and regression test
P0-02	Select next SemVer; never move v1.8.0 tag	Release owner	P0-01	manifest, pyproject, UI and notes aligned
P0-03	Build from exact tracked tree	Release/CI	P0-02	source tree digest bound to artifact
P0-04	Rebuild archive with LICENSE/build-inputs/SBOM/provenance	Release/CI	P0-03	build/trust verifiers PASS
P0-05	Post-install and rollback smoke on clean host	Release/QA	P0-04	reproducible receipts
P0-06	Block promotion unless pytest/lint/version/public-tree pass	CI	P0-01	protected required checks

P1 - security, authority and governance

ID	Работа	Acceptance
P1-01	Replace SECURITY.md template	supported versions, disclosure channel, SLA, coordinated disclosure

ID	Работа	Acceptance
P1-02	Add CI workflow	pytest, Ruff, version, public-tree, acceptance, docs links
P1-03	Protect main	required checks, review, no direct force push
P1-04	Create caller token runbook	generation, storage, client config, rotation, 401 diagnostics
P1-05	Generate auth/admin parity tests from interface inventory	all 438 static interface rows classified
P1-06	Close project-scope matrix	every read/search/update/delete/batch/job/export path
P1-06A	Bind caller project to canonical repository root	/bhm/code-tools mismatch returns 403 before filesystem/index touch
P1-06B	Close anonymous UI bootstrap boundary	default bearer-minted or same-user IPC; shared-host process cannot mint
P1-06C	Redact MCP exception responses	no bearer/API key/DSN/path secret in JSON-RPC error
P1-07	Add Qdrant filter sibling tests	all search modes use project filter
P1-08	Define signed trust anchor registry	pinned fingerprint/rotation/revocation
P1-09	Sign canonical release envelope	archive digest plus signer/provenance metadata
P1-10	Enforce signing key containment	outside source/staging/output, no reparse aliases
P1-11	Build in immutable clean tree	no live-tree TOCTOU, final tree recheck
P1-12	Reconcile .docs canon	PROJECT, NEXT, WORKLIST, plan, receipts
P1-13	Route public AGENTS to local canon	explicit conditional discovery
P1-14	Restore or mark missing receipts unavailable	no fabricated evidence
P1-15	Define resource limit registry	one config/table for every surface
P1-16	Close local-only LLM endpoint policy	IPv4/IPv6, redirect, proxy, timeout, size, fallback
P1-17	Complete successful lifecycle runtime receipt	startup, readiness, shutdown and partial failure
P1-18	Resume Codex Security Deep Scan	six independent passes and centralized validation
P1-19	Replace LangGraph contract drift	persisted graphs only for multi-step resumable flows
P1-20	Remove JSON sidecar authority	SQLite transaction/migration/reconciliation receipts
P1-21	Add REST/MCP schema parity gate	enum/default/bounds/descriptions identical

P2 - reliability and maintainability

ID	Работа	Acceptance
P2-01	Make cleanup audit hermetic	ignored/runtime files cannot change result
P2-02	Replace trusted pytest count in WI17	command executes tests or verifies signed receipt bound to SHA
P2-03	Introduce coverage baseline	measured baseline, staged fail-under increases
P2-04	Define search side-effect contract	read-only flag or explicit projection mutation receipt
P2-05	Decompose app.py slice 1: public/health routers	route/OpenAPI/import parity
P2-06	Decompose app.py slice 2: auth/session middleware	middleware order and test parity
P2-07	Decompose app.py slice 3: memory REST routers	handler/service parity
P2-08	Decompose app.py slice 4: LLM/jobs routers	lifecycle and cancellation parity
P2-09	Decompose app.py slice 5: admin/repair routers	capability parity
P2-10	Extract composition/lifespan	partial-start cleanup tests
P2-11	Split code_graph parser/build/query	graph schema and digest parity
P2-12	Split developer_agent graph/sandbox/telemetry	proposal-only and state parity
P2-13	Audit mcp_readiness fallback path	Windows/no-LOCALAPPDATA matrix
P2-14	Complete process execution inventory	close 268 candidate lines
P2-15	Complete filesystem inventory	close high-impact rows, symlink/junction tests
P2-16	Complete outbound HTTP inventory	local-only/redirect/proxy closure
P2-17	Unified error taxonomy	stable codes, correlation id, safe details
P2-18	Background task registry	ownership, cancellation, exception reporting
P2-19	Bound logs and structured redaction	nested values and export/browser paths
P2-20	Decide local-model replay	execute exact contract or formally retire with rationale

P3 - hygiene

ID	Работа	Acceptance
P3-01	Establish Ruff format migration baseline	dedicated mechanical change, no logic edits
P3-02	Remove Starlette/httpx deprecation warning	compatible dependency/test client path
P3-03	Add docs/link checker	active docs zero broken links; historical exclusions explicit
P3-04	Normalize locked dependency instructions	uv sync --locked --extra build
P3-05	Add architectural metrics	LOC/cyclomatic/dependency trends without hard blocking initially
P3-06	Publish generated interface/boundary inventory	deterministic diff reviewed in CI

16. Phased implementation master plan

Phase 0 - Freeze and evidence contract

Цель: не чинить поверх дрейфующего канона.

Действия:

1. Создать WL-024 для reconciliation этого аудита.
2. Зафиксировать revision, clean tracked tree and runtime state.
3. Определить canonical docs and report ownership.
4. Зафиксировать P0/P1/P2/P3 acceptance matrix.
5. Запретить release promotion до Phase 3.

Rollback: удалить только новый worklist/branch, исходный runtime не менять.

Phase 1 - Canonical documentation reconciliation

1. Синхронизировать PROJECT, NEXT-SESSION, WORKLIST and completion audit.
2. Исправить active/closed contradiction P25.
3. Классифицировать missing receipts.
4. Обновить public AGENTS routing.
5. Добавить decision log: v1.8.0 immutable historical tag.

Gate: one fact - one canonical source; zero stale current-commit claims.

Phase 2 - Version identity

1. Выбрать новый SemVer.
2. Исправить manifest/UI binding.
3. Добавить unit and integration regression.
4. Прогнать version validator, public tree and docs.

Gate: 13/13 version checks.

Phase 3 - Release trust redesign

1. Exact-tree checkout/archive build.
2. Key containment and ACL/reparse validation.
3. Canonical signed envelope.
4. Trusted signer registry.
5. SBOM/provenance/build-inputs.
6. Atomic staging and failure cleanup.
7. Rehash immediately before promotion.

Gate: independent verifier from clean environment.

Phase 4 - CI and governance

1. Add workflow for pytest, Ruff, version, public tree, acceptance and docs.
2. Bind every receipt to commit SHA and tool versions.
3. Protect main.
4. Replace SECURITY.md.

Gate: merge impossible while required check red.

Phase 5 - Auth/admin/project proof

1. Generate full static interface matrix.
2. Classify every route/tool as anonymous, auth-only, project or admin.
3. Compare generated matrix with caller_auth/capability policies.
4. Trace project_id to SQLite/Qdrant/Mem0/jobs/cache/export.
5. Add negative sibling tests.

Gate: zero unclassified mutating interface.

Phase 6 - Lifecycle and hermetic tests

1. Isolate tracked snapshot from .tmp/.runtime.
2. Fix WI17 receipt binding.
3. Add startup/shutdown/partial-start matrix.
4. Add task cancellation and duplicate-job tests.
5. Add before/after SQLite and Qdrant receipts with actor attribution.

Gate: full suite green twice from clean snapshot.

Phase 7 - Read-only semantics

1. Decide whether search access telemetry is a write.
2. Add explicit API metadata/flag.
3. Separate query and accounting if read-only contract required.
4. Test no SQLite/Qdrant mutation in strict read-only mode.

Gate: documented and executable side-effect contract.

Phase 8 - Resource, outbound, process and filesystem closure

1. Triage boundary inventory by runtime reachability.
2. Close high-impact rows first.
3. Add common safe wrappers for process, HTTP and paths.
4. Add Windows junction/reparse and Linux symlink tests.
5. Add redirect/proxy/IPv6 local-only tests.

Gate: every applicable high-impact row is reportable, suppressed, not_applicable or explicitly deferred.

Phase 9 - App decomposition

Rules:

- one slice per PR;
- no big-bang rewrite;
- preserve imports/monkeypatch points until migration complete;
- OpenAPI, route count, middleware order and tests must remain identical.

Order:

1. health/public routers;
2. UI/session;
3. auth/project/admin boundary;
4. memory CRUD/search;

5. graph/index;
6. LLM/jobs;
7. telemetry/repair/admin;
8. lifespan/composition.

Phase 10 - Secondary hotspots

1. code_graph.py: parser registry, graph build, query DSL, serialization.
2. developer_agent.py: state graph, model interaction, sandbox/proposal, telemetry.
3. repository_index.py: discovery, parse, persistence, freshness.
4. bhm_mcp.py: tool groups and generated registration.

Gate: module boundaries documented; no behavior change without dedicated ADR.

Phase 11 - Final assurance and release

1. Resume Deep Security Scan when BHM runtime/tool initialization is healthy.
2. Run six independent discovery passes until saturation/cap.
3. Central validation and attack-path analysis.
4. Run full tests, coverage, lint, format baseline, version and public-tree.
5. Build/sign/verify release from exact tree.
6. Clean-host install, rollback and recovery smoke.
7. Publish only after operator approval.

17. Definition of Done

Задача реализации считается закрытой только если:

- all P0 and chosen P1 items have evidence-bound closure;
- pytest green from clean tracked snapshot;
- coverage threshold recorded and enforced;
- version/public-tree/release trust gates green;
- exact commit equals artifact provenance;
- no historical tag moved;
- auth/admin/project matrices have zero unknown mutating rows;
- local-only LLM invariant has executable tests;
- strict read-only mode has zero hidden mutations;
- startup/shutdown and partial-start cleanup receipts exist;
- docs canon and links are aligned;
- security scan tail is complete or explicit operator-approved deferred scope is recorded;
- rollback is tested;
- Git status contains only intended report/implementation changes.

18. Unknowns and runtime-required checks

1. Successful BHM startup under confirmed SQLite writer authority.
2. Reason and intended operator flow for writer gate confirmation.
3. Docker Desktop pinned Qdrant image recovery.
4. Exact current SQLite hash drift actor; earlier and later hashes cannot be compared without a phase-local before/after pair.
5. Full live MCP surface after restart; static 186 definitions and previously attached 35 tools are distinct evidence classes.
6. Full deep-security validation of release-signing candidates.
7. Exhaustive global object-id project ownership.
8. Complete local-only endpoint algorithm at runtime.
9. 20 000-call local model replay completion.

10. External independent signer authority; current receipts indicate local operator authority.

Appendix A - 56-point Code Review matrix

#	Check	Status	Evidence/backlog
1	Ошибочные условия	Partial	version/UI contract and runtime gates reviewed
2	Недостижимый код	Deferred	module-wide control-flow sweep in decomposition
3	Неправильные defaults	Partial	auth defaults fail-closed; runtime fallback path open
4	Потеря данных	No confirmed loss	SQLite authority; release/runtime gaps
5	Частичные обновления	Partial	transactions and batch paths need generated tests
6	Несогласованное состояние	Confirmed risk	stale docs/release identity; projection side effect
7	None handling	Partial	covered by tests; no exhaustive proof
8	Type errors	Partial	Ruff/tests green except unrelated hermetic failure
9	Exception misuse	Partial	runtime fail-closed; broad except inventory pending
10	Windows/Linux behavior	Partial	Windows path/runtime fallback and reparse tests open
11	Blocking calls in async	Deferred	41 async/background candidate lines
12	Forgotten await	No confirmed finding	dedicated async lint/test recommended
13	Unmanaged background tasks	Partial	job/cancel routes exist; registry not proven
14	Unhandled task exceptions	Partial	lifecycle test backlog
15	Shared mutable state	Architecture risk	app.py global composition
16	Lock misuse	Deferred	startup/shutdown/concurrency package
17	Startup/shutdown races	Runtime required	bootstrap currently fails before ready
18	HTTP/connection/file leaks	Deferred	lifecycle closure
19	Retry/timeout problems	Partial	full outbound/process matrix open
20	Duplicate job processing	Deferred	concurrency tests required
21	Transaction correctness	Partial	SQLite acceptance strong; exhaustive batch closure open
22	SQLite/Qdrant/Mem0 consistency	Partial	authority model clear; telemetry side effect
23	Missing filters	Partial	project/Qdrant sibling tests
24	Incorrect update/delete	Partial	admin/project matrix needed
25	Unbounded selections	Partial	resource limit registry
26	Ambiguous project_id	Partial	default project and global IDs require closure
27	Stale cache	Partial	LLM/cache and projection freshness
28	Migration errors	Partial	schema gates exist; lifecycle runtime unavailable
29	Incomplete related deletion	Partial	artifact/link integrity tests needed
30	Oversized files	Confirmed risk	app.py 16 237 LOC
31	Multi-responsibility functions/modules	Confirmed risk	app.py and agent/graph hotspots
32	API/business/data mixing	Confirmed risk	app.py
33	Cyclic dependencies	Deferred	dependency graph gate
34	Global mutable state	Architecture risk	composition globals/caches
35	Hidden side effects	Confirmed	search schedules Qdrant payload update
36	Duplicated rules	Partial	auth/admin/version/config parity generation
37	Duplicated config	Confirmed risk	version/docs/runtime sources
38	Hard-to-test components	Confirmed risk	monolith and monkeypatch reliance
39	Excessive coupling	Confirmed risk	app/graph/agent hotspots
40	Architectural documentation mismatch	Confirmed	.docs stale and contradictory
41	Broad except	Deferred	error-handling sweep
42	Ignored exceptions	Partial	runtime scripts/logging review
43	Inconsistent error handling	Partial	unified taxonomy missing

#	Check	Status	Evidence/backlog
44	Internal detail disclosure	No confirmed finding	redaction/error tests required
45	Lost error context	Partial	correlation/error taxonomy
46	Logs without context	Partial	structured logging matrix
47	Oversized log objects	Deferred	output/log bound tests
48	Missing correlation identifiers	Partial	not uniformly proven
49	Missing background-operation events	Partial	job telemetry exists, parity open
50	Important components not tested	Confirmed gap	release provenance and generated parity
51	Error branches not tested	Confirmed gap	startup partial failure, version UI
52	Integration tests needed	Confirmed gap	auth/admin/project/release/runtime
53	Concurrency tests needed	Confirmed gap	jobs, locks, cancellation, projection
54	Shutdown/startup tests needed	Confirmed gap	writer gate and child cleanup
55	Tests tied to implementation	Confirmed	monkeypatched access telemetry
56	Negative scenarios/callers/tests before finding	Applied/Gap	promoted findings traced; deep-security candidates remain probable

Appendix B - Component attributes

Для каждого крупного компонента реализационный backlog должен поддерживать восемь обязательных атрибутов:

1. path;
2. classes/functions;
3. responsibility;
4. inputs;
5. outputs;
6. external dependencies;
7. callers;
8. callees.

Эти атрибуты должны стать generated architecture inventory, чтобы будущие карты не зависели от ручного пересказа.

Appendix C - Приоритет следующего действия

Первый безопасный implementation order:

1. WL-024 and canon reconciliation.
2. Version marker regression.
3. CI minimum gates.
4. New SemVer decision.
5. Exact-tree release build/trust redesign.
6. Hermetic full-suite repair.
7. Auth/admin/project generated parity.
8. Runtime lifecycle recovery and receipt.
9. Resume Deep Security Scan.
10. Only then staged architecture decomposition.